



MONTANA

DATA COMPANY

SAAS DATA PROTECTION – THE M365 BLIND SPOT

Montana Data Company (Pty) Ltd
Suite 24, Frazzitta Business Park
Corner Langeberg & Batis Roads
Durbanville
Western Cape
7550
South Africa

Disclaimer

The information contained in this document is provided by Montana Data Company (Montana) for general informational and educational purposes only. While every effort has been made to ensure that the content is accurate, current, and relevant at the time of publication, no representation or warranty, express or implied, is made regarding the completeness, accuracy, reliability, suitability, or availability of the information contained herein.

Each organisation is unique and therefore faces unique operational, legal, regulatory, cybersecurity, and business continuity challenges that must be assessed and addressed according to its specific circumstances, risk profile, industry obligations, and operational environment. The guidance, frameworks, checklists, templates, and recommendations contained in this document are intended as general guidance only and may not be suitable for every organisation or situation.

This document does not constitute legal, regulatory, financial, cybersecurity, forensic, insurance, compliance, or other professional advice. Readers should not rely solely on the information contained in this document when making business, legal, technical, operational, or incident response decisions. Independent professional advice appropriate to the organisation's specific circumstances should be obtained where necessary.

Where this document relates to cybersecurity incidents, ransomware response, disaster recovery, compliance, governance, or operational resilience, the content is intended to provide general operational guidance only. It should not be interpreted as legal advice, digital forensic advice, cyber insurance guidance, regulatory guidance, or a substitute for qualified professional consultation during an active incident or compliance matter.

Any references to legislation, standards, frameworks, regulatory requirements, or best practices — including but not limited to privacy laws, data protection obligations, cybersecurity frameworks, business continuity standards, or compliance requirements — may change over time and may vary by jurisdiction. It remains the responsibility of the reader to ensure compliance with all applicable laws, regulations, contractual obligations, and industry-specific requirements.

Montana shall not be liable for any direct, indirect, incidental, consequential, or special loss or damage arising from the use of, or reliance on, the information contained in this document.

All content contained in this document remains the intellectual property of Montana unless otherwise stated. This material may not be reproduced, distributed, modified, republished, or transmitted in any form or by any means without prior written permission, except for reasonable internal business use by the original recipient.

Any third-party products, services, trademarks, standards, vendor names, or technologies referenced in this document remain the property of their respective owners and are referenced for informational purposes only. Such references do not imply endorsement, partnership, or affiliation unless explicitly stated.

By accessing, downloading, or using this document, the reader acknowledges and agrees to the terms of this disclaimer.

Last Updated: April 2026

Introduction

Microsoft's shared responsibility model means your Microsoft 365 data may not be fully protected.

This guide explains what Microsoft covers, what remains your responsibility, and how to reduce the risk of data loss, ransomware, and compliance failures.

Many organisations assume that because their email, files, and collaboration tools are hosted in Microsoft 365, their data is automatically backed up and fully recoverable.

This is a dangerous misconception.

While Microsoft provides infrastructure resilience and limited retention capabilities, customers remain responsible for protecting their own data, ensuring recoverability, and meeting compliance obligations.

Understanding the Shared Responsibility Model

Microsoft operates on a shared responsibility model.

Microsoft is responsible for maintaining the availability and security of the cloud infrastructure, while customers remain responsible for protecting their own data, managing access controls, configuring retention policies, and ensuring recoverability after accidental deletion, malicious activity, or ransomware attacks.

What Microsoft 365 Protects

- Platform uptime and service availability
- Physical datacentre security
- Infrastructure redundancy
- Basic retention capabilities
- Authentication and identity services
- Limited recycle bin and retention functionality

What Microsoft 365 Does NOT Fully Protect

- Accidental deletion after retention periods expire
- Malicious insider activity
- Ransomware-encrypted files synchronised across devices
- Corrupted or overwritten data
- Misconfigured retention policies
- Long-term point-in-time recovery
- Third-party application integrations
- Compliance-specific archival requirements

Common Risk Scenarios

1. A user permanently deletes important emails and the retention period expires.
2. Ransomware encrypts OneDrive or SharePoint files which are then synchronised to the cloud.
3. A disgruntled employee deletes Teams conversations or SharePoint libraries.
4. An administrator misconfigures retention settings, causing permanent data loss.
5. Legal or audit requests require historical data that no longer exists in Microsoft 365.

Why Native Retention Is Not a Backup Strategy

Retention policies and recycle bins are not substitutes for proper backup systems.

Native retention tools are designed primarily for operational continuity and limited recovery scenarios.

They may not provide independent copies of data, immutable storage, granular recovery, or long-term retention needed for business resilience.

The Business Impact of Data Loss

- Operational disruption
- Regulatory penalties and compliance failures
- Loss of intellectual property
- Reputational damage
- Legal exposure
- Financial losses caused by downtime or reconstruction efforts

Key Components of a Proper Microsoft 365 Backup Strategy

A robust Microsoft 365 data protection strategy should include:

- Independent backups stored outside the Microsoft 365 tenant
- Immutable backup storage to prevent tampering
- Automated backup schedules
- Granular recovery capabilities for emails, files, Teams data, and SharePoint content
- Multi-region or offsite backup storage
- Long-term retention policies aligned to compliance requirements
- Regular recovery testing and validation

Critical Workloads That Must Be Protected

- Exchange Online mailboxes
- OneDrive for Business
- SharePoint Online
- Microsoft Teams data
- Planner and collaboration data
- Entra ID / Azure AD configurations
- Power Platform and automation workflows

Ransomware and Microsoft 365

Modern ransomware attacks increasingly target cloud-based collaboration environments.

If encrypted files synchronise to SharePoint or OneDrive, the encrypted versions may overwrite clean copies.

Without independent backups, recovery options can be severely limited.

Compliance and Regulatory Considerations

Organisations subject to POPIA, GDPR, financial regulations, or industry-specific compliance frameworks may require demonstrable retention, recoverability, and auditability of business data.

Failure to recover critical information may create legal and regulatory exposure.

Questions Every Organisation Should Ask

- Can we recover deleted data older than 90 days?
- Can we restore a single mailbox or file quickly?
- Do we have immutable backups?
- Are backups stored independently from Microsoft 365?
- Have we tested recovery recently?
- How long would it take to fully restore operations?
- Are we meeting our compliance obligations for data retention?

Best Practices Checklist

- Implement independent Microsoft 365 backups
- Use immutable backup storage
- Enable MFA for all administrative accounts
- Apply least-privilege access controls
- Review retention policies regularly
- Monitor for suspicious activity
- Test recovery procedures quarterly
- Document recovery processes and responsibilities

Conclusion

Microsoft 365 delivers powerful productivity capabilities, but it does not eliminate the need for dedicated data protection.

Understanding the limits of Microsoft's responsibility is critical for reducing operational, financial, and compliance risk.

A well-designed SaaS backup and recovery strategy ensures your organisation can recover quickly from accidental deletion, cyberattacks, and operational failures.

Quick Assessment Checklist

- ☐ We have a dedicated Microsoft 365 backup solution
- ☐ Our backups are stored independently from Microsoft 365
- ☐ We use immutable backup storage
- ☐ We can recover individual emails and files quickly
- ☐ We regularly test restoration procedures
- ☐ We have documented retention requirements
- ☐ Administrative accounts use MFA
- ☐ We monitor for unusual deletion activity
- ☐ We have defined RTO and RPO objectives for Microsoft 365 workloads
- ☐ We understand our compliance retention obligations

Contact Us

If you would like to discuss your organisation's specific requirements, risks, compliance obligations, cybersecurity posture, business continuity strategy, or operational resilience objectives in greater detail, we invite you to contact Montana Data Company.

Our team can assist with tailored assessments, strategic guidance, governance support, and practical implementation aligned to your organisation's unique operational and regulatory environment.

Email: info@montanadc.com

Phone: 087 188 3843